CyberRiskGuardian Desktop 1.9.2 Beta — First-time setup

English below · Français plus bas

Document 2 of 2. Start here once **Document 1 — First-time installation** is done and the bottom of the left menu shows ✓ **Engine verified** (click it to see the totals: MediBec 84,305 / 41,023 · CanaRetail 27,526 / 16,049).

This guide prepares the application for real work, in order: where files go, the update check, backups, the rules to settle before any real organizational data goes in, which modules you need, AI (later, and only if you want it), your first assessment, and a routine for afterwards. Allow one to two hours, most of it on the teaching case in section 7.

Everything up to section 6 works **with AI off and no network**. That is deliberate: you learn the application and verify it before anything can leave your computer.

Finding the screens. Help is the button in the top bar (*Help on this screen*, *Step by step*, *User guide*, *Ask the help chatbot*, *About & versions*). Every other path, such as **Tools → Backup & restore**, starts in the **left-hand menu**: the section first, then the screen. Many screens also open from their group on the **Process** page; where that helps, the guide gives both routes.

English

1. Move the feeds folder somewhere you back up

The feeds folder holds everything the application writes outside your browser: downloaded threat sources, the weekly briefing, the AI routing settings and the update ZIPs. By default it is `~/Downloads/CyberRiskGuardian-feeds` (Windows: `%USERPROFILE%\Downloads\CyberRiskGuardian-feeds`), and Downloads is a folder that gets tidied.

1. Create the folder you want, for example `~/Documents/CyberRiskGuardian-feeds`.
2. In the application folder (the folder you unzipped, where the launcher is), create a plain text file `feeds-dir.txt` holding that one path on its first line, and nothing else.
3. Restart the launcher. **Settings → Links & shared folders** shows the folder in use.

> If someone sent you the application, check whether a `feeds-dir.txt` came with it. If it names a folder on *their* computer, replace the path with yours.

Your API keys are never in this folder: on macOS they go to the login keychain; elsewhere they are stored in your user profile so that only you can read them.

2. Decide on the update check

At first start the application asked **Check for updates at start-up?** You can change the answer in **Help → About & versions**.

Choice	What happens	Choose it when
Off (the default)	The application never contacts anything on its own. **Check now** in the same place asks once, when you click.	You work offline or under a strict no-egress rule. Then click **Check now** before each new assessment.
On	At each start the helper asks GitHub for the latest release, at one fixed address, sending nothing about you or your workspaces.	You want to be told.

Either way a newer release is only **downloaded** when you click **Download** (into the feeds folder, verified against its published checksum), and never installed for you.

3. Make your first backup — and know how to restore it

Your workspaces live in the browser's storage for the address you use, not in the application folder. Clearing the browser's site data for that address deletes them.

1. **Tools → Backup & restore → Make a backup → Download backup.** One file holds every workspace, your context documents (by default), the catalogues you loaded and the helper settings, with a SHA-256 checksum. **API keys are never included.**
2. Move the file somewhere backed up — the same place as your feeds folder is fine.
3. Look once at the restore side of the same screen: it labels every workspace in a file *New here*, *Identical*, *Brought forward* or *Would lose work* before it does anything. Knowing this now saves a bad moment later. After a restore the application reopens on the Process page.

A backup is also how you move to another computer, another browser or another port: back up here, restore there.

4. Before you enter real organizational data

Teaching cases are fictional. A real organization's assessment is confidential material: crown jewels, weaknesses, incidents, budgets. Settle these points **before** the first real document goes in.

✓	Rule	How
☐	**You are allowed to keep this data here.** Your client's or employer's rules on where assessment data may be stored apply to this computer and its backups.	Check them; write down the answer in the workspace's evidence register.
☐	**Nothing leaves this computer until you have decided it may.** Until section 6, switch off remote AI for the whole installation.	**Settings → AI — local & remote** → untick **Allow requests to a provider off this machine**. The helper enforces it, whatever a page asks.
☐	**No external AI provider sees client data without authorization.** If you later use a remote provider, get the organization's written authorization first.	Record it as evidence. Section 6 explains the safeguards.
☐	**The workspace is marked as a real organization and as confidential.**	When creating it, choose **Real organization** (section 7.2). Then **Settings → AI — local & remote** → this workspace → **Treat as confidential** and **Anonymize before sending**.
☐	**Always the same address.**	Start with the launcher, on the same port, every time.

✔	Rule	How
☐	**A backup after every working session** on a real workspace.	Section 3.
☐	**What leaves is anonymized and checked.**	Run **Governance → Quality review** before any report or package leaves; sharing to the Risk Registry is anonymized by default — leave it so.

If you later connect the ontology's MCP server, the organisation graphs it builds are kept in `~/CyberRiskGuardian-confidential/crgo/<workspace>` — client data: treat that folder like the others.

5. Choose your modules and the level of detail

At first start the **Process** page invites you to **Set up the application for your practice**. Click **Answer the set-up questions**: about two minutes of yes / no / not sure questions, built on the table below, switch the modules on or off for you, and one question about your experience sets the **level of detail**. **Skip — keep the defaults** keeps everything as it is; **Settings → Modules → Answer the set-up questions again** brings the questions back at any time.

Settings → Modules switches features on or off for this installation. Switching a module off removes it from the menu and **deletes nothing**: its data stays in each workspace and comes back when you switch it on again. Every module is **on** by default **except** Identity & access management and Configuration management.

Group	Module	What it adds	Keep it on (or switch it on) if…	Can be off if…
Governance	Information security management	Scope, security objectives, management reviews, policy exceptions	you run or assess an ISMS (ISO/IEC 27001 style)	you only produce a risk assessment
Governance	Information Security Policy (ISP) management	Policy library, editor, approved versions, acknowledgements, non-compliance	you maintain the organization's security policies	policies are managed elsewhere
Governance	Security Policy Writer	Drafts policies, standards and procedures (EN/FR) from an interview and documents; Word export	you write or rewrite policies — **works best with AI**	you do not write policies
Governance	Cybersecurity management	Control testing by line of defence, governing bodies, delegations, decision records, incident register	you need decisions recorded under a named authority	— keep it on; risk decisions use it
Governance	**Identity & access management (IAM/PAM)** — *off by default*	Population-level registers of accounts, privileged roles, emergency accounts, access reviews, segregation of duties; six KRIs; findings become evidence and scenario proposals	identity, privilege or segregation of duties is in your scope, or a recent audit raised access findings	access is out of scope

Group	Module	What it adds	Keep it on (or switch it on) if…	Can be off if…
Governance	**Configuration management** — *off by default*	Versioned baselines, deviations and their exceptions, configuration changes; three KRIs; findings become evidence and scenario proposals	hardening baselines, drift or change control matter to the scenarios you assess	configuration is out of scope
Governance	Shared registers	Evidence, corrective actions, exceptions and mappings kept once for every module	—	**keep it on**
Governance	Quality review	The checks to run before a report leaves	—	**keep it on**
Compliance and audit	Compliance management	Obligations, legal applicability, framework mappings, campaigns, determinations, regulatory calendar	you must show compliance (Law 25, ISO/IEC 27001, NIST CSF 2.0, PCI DSS…)	compliance is handled elsewhere
Compliance and audit	Audit management	Audit universe, plan, engagements, SP 800-53A procedures, workpapers, findings, follow-up	you are an internal or external auditor	you do not audit
Security operations	SIEM	Telemetry sources, detection rules, coverage, alerts imported from files	you assess detection coverage with SOC data	no SOC data is available
Security operations	SOAR	Cases, incidents, playbooks, approval gates, dry-run simulations	you assess or exercise incident response	as above
Other features	Risk Registry	A catalogue of risks shared between organizations, anonymized contributions	you belong to a community of practice that shares risks	you work alone
Other features	Threat feeds & social	Weekly briefing from public threat feeds, matched to your scenarios	you follow threats week by week	you do not need a briefing
Other features	Ontology · CRGO	Scenario library linked to techniques, weaknesses, controls and obligations	—	**keep it on**: scenario generation uses it
Other features	Virtual consultant	Questions answered from passages retrieved on this computer	you will set up AI (section 6)	you will not use AI
Other features	Scenario screening	The twelve screening criteria (Process steps 6–7)	—	**keep it on**: the method needs it
Other features	Forecasts	KRI and risk forecasts, mitigation optimizer	you track KRIs over time	one-off assessment

Group	Module	What it adds	Keep it on (or switch it on) if…	Can be off if…
Other features	Budget	Multi-year budget arbitrage between initiatives	you calibrate the cybersecurity budget (Process step 18)	no budget work

A typical first set-up for a consultant doing a risk assessment: keep the defaults, switch off SIEM, SOAR and Audit management unless they are part of the mandate, and switch on IAM/PAM or Configuration management only when they are in scope. You can change this at any time.

The level of detail — **Minimal**, **Standard** (the default) or **Detailed** — is switched in **Settings → Language & detail** or in the header of the Process page. *Detailed* adds, under each screen title, one line saying why the screen matters, and opens the tips and guidelines of the next step on the Process page: choose it for a first assessment. *Minimal* removes the introductions and explanatory hints for people who know the method; hints that change what a value means (blank versus 0, the evidence tags, units) stay at every level. No number and no workspace changes with the level. In multi-user mode each signed-in person has their own.

6. Adding AI later — when you are ready

The application never needs AI to calculate: the engine computes every number, and AI only **proposes and explains**. Before anything is sent, a **preview** shows the exact payload, its size and its destination, and you may edit it; nothing is sent until you press **Send**, and everything is logged.

Choose **one** of the two routes, in **Settings → AI — local & remote**.

Route A — a model on this computer (recommended first). Nothing leaves your machine.

1. Install a local model server — **Ollama** or **LM Studio** — and download a model of your choice with it.
2. In **Providers**, open the card of that server (*on this machine*), click **List models**, choose the model, and click **Test this provider** (it sends a few tokens and no workspace data).
3. The **Virtual consultant** is routed to the local model by default; so are the most sensitive tasks. They go to the first local provider whose test passed; **Default providers** on the same page lets you choose another one.
4. Optional: under **Virtual consultant — retrieval**, set an embedding model on this machine and **Build the vector index** to switch a workspace from lexical to hybrid retrieval.

Route B — a remote provider such as the Claude API. Better answers; costs money; data leaves your computer.

1. Get the organization’s authorization first (section 4).
2. Tick **Allow requests to a provider off this machine** again.
3. In **Providers**, open the **Claude API** card (or another provider), paste your key and click **Test this provider**. The helper stores the key in the macOS keychain (elsewhere, in your user profile where only you can read it); it never appears in a configuration file, a log, an export or a backup.
4. For each real workspace keep **Treat as confidential** (every call confirmed) and **Anonymize before sending** on. Use **Restore the recommended routes** to keep the sensitive features on the local model.

Whatever the route, AI output is an **analytical hypothesis**: values not supported by documents are tagged ASSUMPTION, EXTERNAL or UNKNOWN, never FACT, and the consultant marks general knowledge *Analytical estimate — validation required*.

7. Your first assessment

7.1 Warm up on CanaRetail (one sitting)

CanaRetail is a fictional national retailer: ten scenarios, risk-neutral appetite, payment security as the thread, available in English and French.

1. **Organization → Organization profile → Workspaces**: create a workspace, and in **Start from** choose **Teaching example: CanaRetail — national retail (English)** (or *(French)*). The application reopens on the new workspace.
2. Open **Process**, the first item of the menu. Walk the nineteen steps from top to bottom: each step opens its screen in one click and says when it is done. Look, do not change anything yet.
3. Open the **Risk calculator** — left-hand menu → **Risk assessment** → **Risk calculator** (or *Open Risk calculator* in its group on the Process page) — and check the totals **27,526 / 16,049**.
4. Now change one parameter of one scenario in the **Scenario editor** (left-hand menu → **Risk assessment**, or from the Process page) and watch the calculator, the register and the management summary follow. This is how the method behaves.
5. When finished, **Organization → Reset data → Start over** returns the case as shipped.

7.2 Your own organization

1. **Organization → Organization profile → Workspaces**: name the workspace, choose **Real organization**, start from **Blank assessment**, and drop the context documents you are allowed to use (section 4) — business description, organization chart, audit reports, incident history. They are read on this computer. Under **Extract from the documents** the form offers **four extraction options**: *Extract the profile & appetite from these documents after creation*, *Then extract the crown jewels*, *Then extract more from the documents (Import from documents)* and *Also extract policy facts for the Security Policy Writer*. All four are extractions. *With AI off*, leave all four unticked and fill **Profile & appetite** and **Crown jewels** yourself. Even a ticked option sends nothing by itself: each extraction first asks you to choose **AI** (with a preview of what is sent) or **Rules only** (offline, no AI). **Starting an extraction later.** If the options were left unticked at creation, or you switch AI on afterwards, you start each extraction yourself from **Organization → Organization profile**. First check that your documents appear under the **Context documents** tab and, for AI, that your provider passes **Test this provider** (**Settings → AI — local & remote**). Then: **Profile & appetite → Extract from documents… → Use AI** (or **Rules only**) → check the preview → **Send**. You get a proposal for each field to accept or edit, and nothing is saved until you click **Save**. The **Crown jewels** tab has the same button, and the **Import from documents** tab covers everything else (assets, controls, incidents, candidate scenarios…) through **Start the import**. The **Process** page shows the same route: while the context is incomplete and documents exist, the step-2 card carries **Extract from documents…** and says what it needs (documents, a tested AI provider or Rules only).
2. Apply section 4 to this workspace now (confidential, anonymize, backup).
3. Follow **Process** step by step. The dark **Next step** card says what the step still needs, check by check, and its first button opens the screen where the next thing is done. **Help → Step by step** opens beside it; **Print the checklist** gives you a paper list to tick. For a first real assessment, the quick version is enough: 20 candidate scenarios, ten selected.
4. Before you rely on a number: every estimate has a rationale and a confidence level; anything not documented carries **Analytical estimate — validation required** or **Information gap — organizational validation required**.
5. Before anything leaves: **Governance → Quality review**, then the **Management summary** (left-hand menu → **Risk assessment** → **Management summary**, or from its group on the Process page). Decisions to accept, treat, transfer or avoid a risk belong to management, recorded under a named

authority.

8. After your first assessment — a routine that keeps it alive

How often	What	Where
After every working session on a real workspace	Back up, and store the file somewhere backed up	Tools → Backup & restore
Weekly, if you follow threats	Download current sources and triage the week's briefing	Threats & vulnerabilities → Threat feeds & social
Before each assessment, at least every 90 days	Replace the bundled example threat snapshot with current KEV and EPSS (it is a fixed date and expires on 31 January 2027)	Threats & vulnerabilities → Threat context
Monthly, or before a new assessment	Check for a new release (then back up before upgrading — see the upgrade section of the installation guide)	Help → About & versions → Check now
At each review (quarterly is usual)	Record the KRI measurements	Risk assessment → KRI dashboard
Every 12 months, or after a material change (incident, acquisition, new system, new law)	Reassess: the horizon of the method is the next 12 months	Process

More help: Help in the top bar — *User guide* (complete reference), *Step by step*, *Help on this screen* — and the **?** beside the title of every screen. Licences and questions: **sales@cyberriskguardian.ca**.

Français

Document 2 de 2. Commencez ici une fois le **Document 1 — Première installation** terminé et le bas du menu de gauche affichant ✓ **Moteur vérifié** (cliquez dessus pour voir les totaux : MediBec 84,305 / 41,023 · CanaRetail 27,526 / 16,049).

Ce guide prépare l'application au travail réel, dans l'ordre : où vont les fichiers, la recherche de mises à jour, les sauvegardes, les règles à fixer avant d'entrer des données d'une vraie organisation, les modules dont vous avez besoin, l'IA (plus tard, et seulement si vous la voulez), votre première analyse et une routine pour la suite. Prévoyez une à deux heures, surtout pour le cas pédagogique de la section 7.

Tout, jusqu'à la section 6, fonctionne **sans IA et sans réseau**. C'est voulu : vous apprenez l'application et la vérifiez avant que quoi que ce soit puisse quitter votre ordinateur.

Trouver les écrans. Aide est le bouton de la barre supérieure (*Aide sur cet écran*, *Pas à pas*, *Guide de l'utilisateur*, *Demander à l'agent conversationnel d'aide*, *À propos et versions*). Tout autre chemin, comme **Outils → Sauvegarde et restauration**, part du **menu de gauche** : la section d'abord, puis l'écran. Beaucoup d'écrans s'ouvrent aussi depuis leur groupe sur la page **Processus**; quand c'est utile, le guide donne les deux chemins.

1. Déplacer le dossier des flux vers un endroit sauvegardé

Le dossier des flux contient tout ce que l'application écrit hors de votre navigateur : les sources de menace téléchargées, le breffage hebdomadaire, les réglages d'acheminement de l'IA et les ZIP de mise à jour. Par défaut, c'est `~/Downloads/CyberRiskGuardian-feeds` (Windows : `%USERPROFILE%\Downloads\CyberRiskGuardian-feeds`), et Téléchargements est un dossier dont on fait régulièrement le ménage.

1. Créez le dossier voulu, par exemple `~/Documents/CyberRiskGuardian-feeds`.
2. Dans le dossier de l'application (le dossier que vous avez décompressé, où se trouve le lanceur), créez un fichier texte simple **`feeds-dir.txt`** contenant ce seul chemin sur sa première ligne, et rien d'autre.
3. Redémarrez le lanceur. **Paramètres → Liens et dossiers partagés** affiche le dossier utilisé.

> Si quelqu'un vous a transmis l'application, vérifiez si un `feeds-dir.txt` l'accompagne. S'il désigne un dossier situé sur *son* ordinateur, remplacez le chemin par le vôtre.

Vos clés d'API ne sont jamais dans ce dossier : sous macOS, elles vont dans le trousseau de session; ailleurs, elles sont conservées dans votre profil d'utilisateur, lisibles par vous seul.

2. Décider de la recherche de mises à jour

Au premier démarrage, l'application a demandé **Rechercher les mises à jour au démarrage ?** Vous pouvez changer la réponse sous **Aide → À propos et versions**.

Choix	Ce qui se passe	Choisissez-le quand
Désactivé (par défaut)	L'application ne contacte jamais rien d'elle-même. **Vérifier maintenant**, au même endroit, interroge une fois, quand vous cliquez.	Vous travaillez hors ligne ou sous une règle stricte d'aucune sortie réseau. Cliquez alors sur **Vérifier maintenant** avant chaque nouvelle analyse.
Activé	À chaque démarrage, l'assistant local demande à GitHub la plus récente version, à une seule adresse fixe, sans rien envoyer sur vous ou vos espaces de travail.	Vous voulez être prévenu.

Dans les deux cas, une nouvelle version n'est **téléchargée** que si vous cliquez sur **Télécharger** (dans le dossier des flux, vérifiée par rapport à sa somme de contrôle publiée), et elle n'est jamais installée à votre place.

3. Faire votre première sauvegarde — et savoir la restaurer

Vos espaces de travail résident dans le stockage du navigateur, pour l'adresse que vous utilisez, et non dans le dossier de l'application. Effacer les données du site pour cette adresse les supprime.

1. **Outils → Sauvegarde et restauration → Faire une sauvegarde → Télécharger la sauvegarde.** Un seul fichier contient tous les espaces de travail, vos documents de contexte (par défaut), les catalogues chargés et les réglages de l'assistant local, avec une somme de contrôle SHA-256. **Les clés d'API ne sont jamais incluses.**
2. Déplacez le fichier vers un endroit sauvegardé — le même que votre dossier des flux convient.

3. Regardez une fois le côté restauration du même écran : avant de faire quoi que ce soit, il étiquette chaque espace de travail du fichier (*Nouveau ici*, *Identique*, plus récent, ou qui ferait perdre du travail). Le savoir maintenant vous évitera un mauvais moment plus tard. Après une restauration, l'application se rouvre sur la page Processus.

Une sauvegarde est aussi la façon de passer à un autre ordinateur, un autre navigateur ou un autre port : sauvegardez ici, restaurez là-bas.

4. Avant d'entrer des données d'une vraie organisation

Les cas pédagogiques sont fictifs. L'analyse d'une vraie organisation est de l'information confidentielle : joyaux de la couronne, faiblesses, incidents, budgets. Réglez ces points **avant** que le premier vrai document entre dans l'application.

✔	Règle	Comment
☐	**Vous avez le droit de conserver ces données ici.** Les règles de votre client ou de votre employeur sur l'endroit où les données d'analyse peuvent être conservées s'appliquent à cet ordinateur et à ses sauvegardes.	Vérifiez-les; consignez la réponse dans le registre des éléments probants de l'espace de travail.
☐	**Rien ne quitte cet ordinateur tant que vous ne l'avez pas décidé.** Jusqu'à la section 6, désactivez l'IA distante pour toute l'installation.	**Paramètres → IA — locale et distante** → décochez **Autoriser les requêtes vers un fournisseur hors de cette machine**. L'assistant local l'impose, quoi que demande une page.
☐	**Aucun fournisseur d'IA externe ne voit les données d'un client sans autorisation.** Si vous utilisez plus tard un fournisseur distant, obtenez d'abord l'autorisation écrite de l'organisation.	Consignez-la comme élément probant. La section 6 explique les mesures de protection.
☐	**L'espace de travail est marqué comme organisation réelle et comme confidentiel.**	À la création, choisissez **Organisation réelle** (section 7.2). Puis **Paramètres → IA — locale et distante** → cet espace de travail → **Traiter comme confidentiel** et **Anonymiser avant l'envoi**.
☐	**Toujours la même adresse.**	Démarrez avec le lanceur, sur le même port, chaque fois.
☐	**Une sauvegarde après chaque séance de travail** sur un espace de travail réel.	Section 3.
☐	**Ce qui sort est anonymisé et vérifié.**	Lancez **Gouvernance → Revue de qualité** avant qu'un rapport ou un paquet ne sorte; le partage vers le registre partagé des risques est anonymisé par défaut — laissez-le ainsi.

Si vous branchez plus tard le serveur MCP de l'ontologie, les graphes d'organisation qu'il construit sont conservés dans `~/CyberRiskGuardian-confidential/crgo/<espace de travail>` — des données de client : traitez ce dossier comme les autres.

5. Choisir vos modules et le niveau de détail

Au premier démarrage, la page **Processus** vous invite à **Configurer l'application pour votre pratique**. Cliquez sur **Répondre aux questions de configuration** : environ deux minutes de questions (oui / non / je ne sais pas), fondées sur le tableau ci-dessous, activent ou désactivent les modules pour vous, et une question sur votre expérience règle le **niveau de détail**. **Passer — garder les valeurs par défaut** laisse tout tel quel; **Paramètres → Modules → Répondre de nouveau aux questions de configuration** ramène les questions en tout temps.

Paramètres → Modules active ou désactive des fonctionnalités pour cette installation. Désactiver un module le retire du menu et **ne supprime rien** : ses données restent dans chaque espace de travail et reviennent quand vous le réactivez. Tous les modules sont **activés** par défaut, **sauf** la Gestion des identités et des accès et la Gestion de la configuration.

Groupe	Module	Ce qu'il ajoute	Gardez-le (ou activez-le) si…	Peut être désactivé si…
Gouvernance	Gestion de la sécurité de l'information	Périmètre, objectifs de sécurité, revues de direction, exceptions aux politiques	vous exploitez ou évaluez un SGSI (de type ISO/IEC 27001)	vous produisez seulement une analyse de risques
Gouvernance	Gestion des politiques de sécurité de l'information (PSI)	Bibliothèque de politiques, éditeur, versions approuvées, accusés de lecture, non-conformités	vous tenez à jour les politiques de sécurité de l'organisation	les politiques sont gérées ailleurs
Gouvernance	Rédacteur de politiques de sécurité	Rédige politiques, normes et procédures (FR/EN) à partir d'une entrevue et de documents; export Word	vous rédigez ou réécrivez des politiques — **fonctionne mieux avec l'IA**	vous ne rédigez pas de politiques
Gouvernance	Gestion de la cybersécurité	Essais des contrôles par ligne de défense, instances, délégations, registres de décisions, registre des incidents	vous devez consigner les décisions sous une autorité nommée	— gardez-le : les décisions de risque l'utilisent
Gouvernance	**Gestion des identités et des accès (GIA/GAP)** — *désactivé par défaut*	Registres au niveau des populations : comptes, rôles privilégiés, comptes d'urgence, revues d'accès, séparation des tâches; six ICR; les constats deviennent des éléments probants et des propositions de scénarios	les identités, les privilèges ou la séparation des tâches font partie du périmètre, ou un audit récent a soulevé des constats d'accès	les accès sont hors périmètre
Gouvernance	**Gestion de la configuration** — *désactivé par défaut*	Configurations de référence versionnées, écarts et leurs exceptions, changements de configuration; trois ICR; les constats deviennent des éléments probants et des propositions de scénarios	le durcissement, la dérive ou le contrôle des changements comptent pour les scénarios évalués	la configuration est hors périmètre

Groupe	Module	Ce qu'il ajoute	Gardez-le (ou activez-le) si…	Peut être désactivé si…
Gouvernance	Registres partagés	Éléments probants, mesures correctives, exceptions et correspondances tenus une seule fois pour tous les modules	—	**gardez-le**
Gouvernance	Revue de qualité	Les vérifications à faire avant qu'un rapport ne sorte	—	**gardez-le**
Conformité et audit	Gestion de la conformité	Obligations, applicabilité juridique, correspondances de référentiels, campagnes, déterminations, calendrier réglementaire	vous devez démontrer la conformité (Loi 25, ISO/IEC 27001, NIST CSF 2.0, PCI DSS…)	la conformité est gérée ailleurs
Conformité et audit	Gestion de l'audit	Univers d'audit, plan, mandats, procédures SP 800-53A, dossiers de travail, constats, suivi	vous êtes auditeur interne ou externe	vous ne faites pas d'audit
Opérations de sécurité	SIEM	Sources de télémétrie, règles de détection, couverture, alertes importées de fichiers	vous évaluez la couverture de détection avec des données du COS	aucune donnée du COS n'est disponible
Opérations de sécurité	SOAR	Dossiers, incidents, guides d'intervention, points d'approbation, simulations à blanc	vous évaluez ou exercez la réponse aux incidents	comme ci-dessus
Autres fonctionnalités	Registre partagé des risques	Catalogue de risques partagé entre organisations, contributions anonymisées	vous faites partie d'une communauté de pratique qui partage des risques	vous travaillez seul
Autres fonctionnalités	Flux de menaces et réseaux sociaux	Breffage hebdomadaire tiré de flux publics, rapproché de vos scénarios	vous suivez les menaces semaine après semaine	vous n'avez pas besoin de breffage
Autres fonctionnalités	Ontologie · CRGO	Bibliothèque de scénarios liés aux techniques, faiblesses, contrôles et obligations	—	**gardez-la** : la génération de scénarios l'utilise
Autres fonctionnalités	Consultant virtuel	Réponses tirées de passages récupérés sur cet ordinateur	vous configurerez l'IA (section 6)	vous n'utiliserez pas l'IA
Autres fonctionnalités	Filtrage des scénarios	Les douze critères de filtrage (étapes 6 et 7 du processus)	—	**gardez-le** : la méthode en a besoin
Autres fonctionnalités	Prévisions	Prévisions des ICR et du risque, optimiseur d'atténuation	vous suivez des ICR dans le temps	analyse ponctuelle

Groupe	Module	Ce qu'il ajoute	Gardez-le (ou activez-le) si…	Peut être désactivé si…
Autres fonctionnalités	Budget	Arbitrage budgétaire pluriannuel entre initiatives	vous calibrez le budget de cybersécurité (étape 18 du processus)	aucun travail budgétaire

Une première configuration typique pour un consultant qui fait une analyse de risques : gardez les valeurs par défaut, désactivez SIEM, SOAR et Gestion de l'audit s'ils ne font pas partie du mandat, et n'activez la GIA/GAP ou la Gestion de la configuration que lorsqu'elles sont dans le périmètre. Vous pouvez changer cela en tout temps.

Le niveau de détail — **Minimal**, **Standard** (par défaut) ou **Détaillé** — se règle sous **Paramètres → Langue et détail** ou dans l'en-tête de la page Processus. *Détaillé* ajoute, sous le titre de chaque écran, une ligne qui dit pourquoi l'écran compte, et ouvre les conseils et les lignes directrices de la prochaine étape sur la page Processus : choisissez-le pour une première analyse. *Minimal* retire les introductions et les indications explicatives pour qui connaît la méthode; les indications qui changent le sens d'une valeur (vide ou 0, les étiquettes d'élément probant, les unités) restent à tous les niveaux. Aucun nombre ni aucun espace de travail ne change avec le niveau. En mode multi-utilisateur, chaque personne connectée a le sien.

6. Ajouter l'IA plus tard — quand vous serez prêt

L'application n'a jamais besoin de l'IA pour calculer : le moteur calcule chaque nombre, l'IA ne fait que **proposer et expliquer**. Avant tout envoi, un **aperçu** montre le contenu exact, sa taille et sa destination, et vous pouvez le modifier; rien n'est envoyé avant que vous appuyiez sur **Envoyer**, et tout est journalisé.

Choisissez **une** des deux voies, sous **Paramètres → IA — locale et distante**.

Voie A — un modèle sur cet ordinateur (recommandée d'abord). Rien ne quitte votre machine.

1. Installez un serveur de modèles local — **Ollama** ou **LM Studio** — et téléchargez-y un modèle de votre choix.
2. Sous **Fournisseurs**, ouvrez la fiche de ce serveur (*sur cette machine*), cliquez sur **Lister les modèles**, choisissez le modèle et cliquez sur **Tester ce fournisseur** (il envoie quelques jetons et aucune donnée d'espace de travail).
3. Le **Consultant virtuel** est acheminé vers le modèle local par défaut, tout comme les tâches les plus sensibles. Elles vont au premier fournisseur local dont le test a réussi; **Fournisseurs par défaut**, sur la même page, permet d'en choisir un autre.
4. Facultatif : sous **Consultant virtuel — recherche**, choisissez un modèle de plongement sur cette machine et cliquez sur **Construire l'index vectoriel** pour passer un espace de travail de la récupération lexicale à la récupération hybride.

Voie B — un fournisseur distant comme l'API Claude. De meilleures réponses; cela coûte de l'argent; les données quittent votre ordinateur.

1. Obtenez d'abord l'autorisation de l'organisation (section 4).
2. Cochez de nouveau **Autoriser les requêtes vers un fournisseur hors de cette machine**.
3. Sous **Fournisseurs**, ouvrez la fiche **API Claude** (ou d'un autre fournisseur), collez votre clé et cliquez sur **Tester ce fournisseur**. L'assistant local conserve la clé dans le trousseau de macOS (ailleurs, dans votre profil d'utilisateur, lisible par vous seul); elle n'apparaît jamais dans un fichier de

configuration, un journal, une exportation ou une sauvegarde.
4. Pour chaque espace de travail réel, gardez **Traiter comme confidentiel** (chaque appel confirmé) et **Anonymiser avant l'envoi** activés. **Rétablir les acheminements recommandés** garde les fonctionnalités sensibles sur le modèle local.

Quelle que soit la voie, ce que produit l'IA est une **hypothèse d'analyse** : une valeur que les documents n'appuient pas est étiquetée ASSUMPTION, EXTERNAL ou UNKNOWN, jamais FACT (les étiquettes restent en anglais dans l'interface), et le consultant marque les connaissances générales *Estimation analytique — validation requise*.

7. Votre première analyse

7.1 S'échauffer avec CanaRetail (en une séance)

CanaRetail est un détaillant national fictif : dix scénarios, une appétence neutre au risque, la sécurité des paiements comme fil conducteur, en français et en anglais.

1. **Organisation → Profil de l'organisation → Espaces de travail** : créez un espace de travail et, dans **Partir de**, choisissez **Exemple pédagogique : CanaRetail — commerce de détail national (français)** (ou *(anglais)*). L'application se rouvre sur le nouvel espace de travail.
2. Ouvrez **Processus**, le premier élément du menu. Parcourez les dix-neuf étapes de haut en bas : chacune ouvre son écran en un clic et dit quand elle est terminée. Regardez, sans rien changer encore.
3. Ouvrez le **Calculateur de risque** — menu de gauche → **Évaluation des risques → Calculateur de risque** (ou *Ouvrir le calculateur de risque* dans son groupe sur la page Processus) — et vérifiez les totaux **27,526 / 16,049**.
4. Changez ensuite un paramètre d'un scénario dans l'**Éditeur de scénarios** (menu de gauche → **Évaluation des risques**, ou depuis la page Processus) et voyez le calculateur, le registre et le sommaire de gestion suivre. C'est ainsi que se comporte la méthode.
5. Une fois terminé, **Organisation → Réinitialiser les données → Recommencer** remet le cas tel que livré.

7.2 Votre propre organisation

1. **Organisation → Profil de l'organisation → Espaces de travail** : nommez l'espace de travail, choisissez **Organisation réelle**, partez d'une **Évaluation vierge** et déposez les documents de contexte que vous avez le droit d'utiliser (section 4) — description des activités, organigramme, rapports d'audit, historique des incidents. Ils sont lus sur cet ordinateur. Sous **Extraire des documents**, le formulaire offre **quatre options d'extraction** : *Extraire le profil et l'appétence de ces documents après la création*, *Puis extraire les joyaux de la couronne*, *Puis extraire davantage des documents (Importer des documents)* et *Extraire aussi les faits utiles aux politiques pour le rédacteur de politiques de sécurité*. Les quatre sont des extractions. *Sans IA*, laissez les quatre décochées et remplissez vous-même **Profil et appétence** et **Joyaux de la couronne**. Même cochée, une option n'envoie rien d'elle-même : chaque extraction vous demande d'abord de choisir **IA** (avec un aperçu de ce qui est envoyé) ou **Règles seulement** (hors ligne, sans IA). **Lancer une extraction plus tard.** Si les options sont restées décochées à la création, ou si vous activez l'IA ensuite, vous lancez chaque extraction vous-même depuis **Organisation → Profil de l'organisation**. Vérifiez d'abord que vos documents figurent sous l'onglet **Documents de contexte** et, pour l'IA, que votre fournisseur réussit **Tester ce fournisseur** (**Paramètres → IA — locale et distante**). Puis : **Profil et appétence → Extraire des documents… → Utiliser l'IA (aperçu avant l'envoi)** (ou **Règles seulement**) → vérifiez l'aperçu → **Envoyer**. Vous obtenez une proposition pour chaque champ, à

accepter ou à modifier, et rien n'est enregistré avant que vous cliquiez sur **Enregistrer**. L'onglet **Joyaux de la couronne** a le même bouton, et l'onglet **Importer des documents** couvre tout le reste (actifs, contrôles, incidents, scénarios candidats…) par **Démarrer l'importation**. La page **Processus** montre le même chemin : tant que le contexte est incomplet et que des documents existent, la carte de l'étape 2 porte **Extraire des documents…** et dit ce qu'il faut (des documents, un fournisseur d'IA testé ou Règles seulement).

2. Appliquez maintenant la section 4 à cet espace de travail (confidentiel, anonymisation, sauvegarde).
3. Suivez le **Processus** étape par étape. La carte sombre **Prochaine étape** dit ce dont l'étape a encore besoin, vérification par vérification, et son premier bouton ouvre l'écran où se fait la chose suivante. **Aide → Pas à pas** s'ouvre à côté; **Imprimer la liste de contrôle** vous donne une liste papier à cocher. Pour une première analyse réelle, la version rapide suffit : 20 scénarios candidats, dix retenus.
4. Avant de vous fier à un nombre : chaque estimation a une justification et un niveau de confiance; ce qui n'est pas documenté porte **Estimation analytique — validation requise** ou **Lacune d'information — validation organisationnelle requise**.
5. Avant que quoi que ce soit ne sorte : **Gouvernance → Revue de qualité**, puis le **Sommaire de gestion** (menu de gauche → **Évaluation des risques → Sommaire de gestion**, ou depuis son groupe sur la page Processus). Les décisions d'accepter, de traiter, de transférer ou d'éviter un risque reviennent à la direction, consignées sous une autorité nommée.

8. Après votre première analyse — une routine qui la garde vivante

À quelle fréquence	Quoi	Où
Après chaque séance de travail sur un espace de travail réel	Sauvegarder, et ranger le fichier dans un endroit sauvegardé	Outils → Sauvegarde et restauration
Chaque semaine, si vous suivez les menaces	Télécharger les sources courantes et trier le breffage de la semaine	Menaces et vulnérabilités → Flux de menaces et réseaux sociaux
Avant chaque analyse, au moins tous les 90 jours	Remplacer l'instantané de menace fourni en exemple par des KEV et EPSS courants (il a une date fixe et expire le 31 janvier 2027)	Menaces et vulnérabilités → Contexte de menace
Chaque mois, ou avant une nouvelle analyse	Vérifier s'il existe une nouvelle version (puis sauvegarder avant la mise à niveau — voir la section sur la mise à niveau du guide d'installation)	Aide → À propos et versions → Vérifier maintenant
À chaque revue (trimestrielle, habituellement)	Consigner les mesures des ICR	Évaluation des risques → Tableau de bord des ICR
Tous les 12 mois, ou après un changement important (incident, acquisition, nouveau système, nouvelle loi)	Réévaluer : l'horizon de la méthode est les 12 prochains mois	Processus

Plus d'aide : Aide dans la barre supérieure — *Guide de l'utilisateur* (référence complète), *Pas à pas*, *Aide sur cet écran* — et le **?** à côté du titre de chaque écran. Licences et questions : **sales@cyberriskguardian.ca**.